

Questions 1–20

Question 1

An organization deploys an AI inference service using a cloud virtual machine. The security team assumes that because the cloud provider secures the underlying physical infrastructure, the provider is also responsible for patching the guest operating system and configuring the VM's network access controls.

Which assessment is **MOST accurate**?

- A. The assumption is correct because the provider manages all infrastructure security under the shared responsibility model.
 - B. The assumption is incorrect because, in IaaS, the customer remains responsible for security within the cloud, including the guest OS, network configuration, identity, and application configuration.
 - C. The assumption is correct only if the VM is running inside a private VPC.
 - D. The assumption is incorrect because the customer is responsible for physical data-center security in IaaS.
-

Question 2

A machine-learning team discovers that an attacker has inserted carefully crafted records into its training dataset. The model subsequently begins producing systematically incorrect classifications for a subset of inputs.

Which attack has **MOST likely** occurred?

- A. Evasion attack
 - B. Model extraction
 - C. Data poisoning
 - D. Credential replay
-

Question 3

A security architect is evaluating an AI application deployed on a PaaS platform. The team wants to minimize operational overhead while retaining responsibility for application-level IAM policies, data protection, and configuration of the AI workload.

Which statement **BEST** reflects the study guide's treatment of PaaS?

- A. The provider is responsible for all security controls except physical security.
- B. The customer is fully responsible for all infrastructure, operating-system, and application security.
- C. Security responsibilities are shared, with the customer's responsibilities falling between those of IaaS and SaaS depending on the services used.

D. The customer is responsible only for API keys because PaaS provides the same abstraction as SaaS.

Question 4

An attacker repeatedly queries a publicly accessible AI model and uses the responses to train a separate model that approximates the target's behavior. The attacker eventually obtains functionality similar to the proprietary model without access to its original weights.

Which threat does this scenario **BEST** represent?

- A. Data poisoning
 - B. Evasion attack
 - C. Model stealing
 - D. Configuration drift
-

Question 5

A security team is designing controls for an AI workload using the AWS Well-Architected Framework. They want to ensure that the architecture can withstand component failures, automatically recover from failures, and scale horizontally when demand changes.

Which Well-Architected pillar should be the **PRIMARY** focus?

- A. Security
 - B. Reliability
 - C. Operational Excellence
 - D. Cost Optimization
-

Question 6

A development team modifies a dependency used by an AI inference service. Several environments subsequently run different versions of the dependency, making the model deployment difficult to reproduce.

Which combination would **BEST** address the underlying software supply-chain problem?

- A. Disable automated updates and rely exclusively on manual testing.
 - B. Pin dependency versions and use lockfiles with checksums.
 - C. Store all dependencies in the model artifact without version information.
 - D. Grant developers broader IAM permissions to install dependencies dynamically.
-

Question 7

An AI platform has separate teams responsible for data curation, model inference, and infrastructure administration. A security architect wants to minimize the impact of a compromised identity.

Which IAM design **BEST** aligns with the Module 8 guidance?

- A. Give all three teams administrative access but monitor their activity.
 - B. Give each team only the permissions required for its authorized tasks and review policies periodically.
 - C. Use a single service account so permissions can be managed centrally.
 - D. Assign permissions based primarily on organizational seniority.
-

Question 8

A company stores highly sensitive AI training datasets and proprietary trained models in cloud object storage. The organization wants greater control over key rotation and access policies than provider-managed keys provide.

Which approach **BEST** aligns with the Module 8 guidance?

- A. Use customer-managed keys through a Key Management Service.
 - B. Store encryption keys alongside the datasets.
 - C. Disable encryption because access controls already protect the data.
 - D. Use a single permanent encryption key shared by all AI services.
-

Question 9

A company discovers that an employee's credentials have been compromised. The credentials currently allow access to training datasets, model artifacts, inference endpoints, and unrelated cloud resources.

Which change would **BEST** implement the principle of least privilege?

- A. Increase monitoring while retaining the existing permissions.
 - B. Separate permissions by function and grant only the minimum access necessary to each role.
 - C. Require the employee to use a stronger password.
 - D. Move all AI resources into a single VPC.
-

Question 10

An AI application processes highly sensitive training data and provides an inference API. The organization wants to prevent training data and inference traffic from traversing the public internet.

Which architectural control is **MOST appropriate** according to Module 8?

- A. Increase the number of public API gateways.
 - B. Deploy the workload inside a VPC and use private API endpoints.
 - C. Use a larger compute instance for the inference endpoint.
 - D. Disable IAM controls because the workload is privately hosted.
-

Question 11

A security engineer manually provisions three separate environments for AI model training. Over time, the environments develop different network rules, IAM configurations, and encryption settings.

Which solution would **BEST** reduce this configuration-drift risk?

- A. Perform manual reviews every six months.
 - B. Document the differences between environments.
 - C. Use Infrastructure as Code to define and consistently reproduce the desired infrastructure state.
 - D. Allow each environment to evolve independently because development and production have different requirements.
-

Question 12

An AI inference service normally receives approximately 10,000 requests per hour. The monitoring system suddenly detects a tenfold increase in queries accompanied by repeated unusual input patterns.

What should the security team **MOST appropriately** infer from these observations?

- A. The model has necessarily experienced data poisoning.
 - B. The workload may be experiencing adversarial probing or an attempt to extract/copy the model.
 - C. The increase proves that the model's training data has been corrupted.
 - D. The increase is purely a capacity-management issue and has no security significance.
-

Question 13

A distributed AI application follows this request path:

DNS → API Gateway → Serverless Function → Inference Endpoint

An incident investigator needs to determine where a suspicious request originated and how it propagated through the architecture.

Which control would provide the **BEST** capability?

- A. Encrypting the model with a customer-managed KMS key
 - B. Implementing W3C Trace Context using traceparent and tracestate
 - C. Increasing the inference endpoint's compute capacity
 - D. Using a separate IAM role for each developer
-

Question 14

A development organization wants its AI deployment process to support frequent changes while minimizing the risk that a faulty deployment remains in production. The architecture team recommends small, reversible changes and automated rollback capabilities.

Which AWS Well-Architected principle does this **MOST directly** support?

- A. Operational Excellence
 - B. Cost Optimization
 - C. Sustainability
 - D. Performance Efficiency
-

Question 15

A security operations team wants its AI monitoring platform to detect not only infrastructure failures but also potential model-related attacks.

Which monitoring strategy would provide the **BEST** coverage?

- A. Monitor CPU and memory utilization only.
 - B. Monitor infrastructure health, inference behavior, model confidence/distributions, and drift-related indicators.
 - C. Monitor only authentication failures.
 - D. Monitor only network bandwidth because model attacks are network-layer events.
-

Question 16

A vulnerability scanner identifies a critical vulnerability in a third-party library used by an AI application immediately before production deployment.

Which action **BEST demonstrates secure CI/CD practice according to Module 8?**

- A. Deploy the application and investigate the vulnerability afterward.
- B. Suppress the scanner finding because the library is widely used.
- C. Block or prevent the deployment until the vulnerability is appropriately addressed.
- D. Deploy the application but increase application logging.

Question 17

An AI security incident has been detected. Investigators need to examine potentially compromised resources without contaminating evidence or further affecting production systems.

Which approach is **BEST aligned with Module 8 incident-response guidance**?

- A. Perform forensic analysis directly on the production system.
 - B. Immediately delete all compromised resources.
 - C. Use a pre-established clean-room environment for safe and isolated forensic investigation.
 - D. Disable all logging to prevent sensitive information from being exposed.
-

Question 18

An organization is designing disaster recovery objectives for a mission-critical AI service. Management wants the system to tolerate very little downtime and very little data loss.

Which statement is **MOST accurate**?

- A. Lower RTO and RPO objectives generally increase organizational cost.
 - B. Lower RTO and RPO objectives generally decrease organizational cost.
 - C. RTO affects cost, but RPO has no meaningful relationship to cost.
 - D. RTO and RPO are operational metrics that do not influence architecture decisions.
-

Question 19

An organization wants its AI agent to access a sensitive database. The agent authenticated successfully when it was initially created. The team proposes allowing the agent to retain the same authorization indefinitely to avoid operational overhead.

Which approach **BEST aligns with Zero Trust principles in Module 8**?

- A. Trust the agent after its initial authentication because it is an internal service.
 - B. Allow the agent permanent access if its activity is logged.
 - C. Treat the agent as a user-like entity and require real-time verification of each action while granting only the minimum necessary access.
 - D. Allow unrestricted database access but require periodic password changes.
-

Question 20

A company has implemented a Zero Trust architecture but continues to allow unrestricted communication between workloads once they are inside the private cloud network.

Which principle is **MOST clearly being violated**?

- A. All data sources and computing services are considered resources.
- B. All communication is secured regardless of network location.
- C. Access should be granted only to administrators.
- D. Cloud resources should be deployed exclusively using SaaS.

Answer Key & Explanations — Batch 1

Q Answer Explanation

- | | |
|-----|---|
| 1 B | Under the Shared Responsibility Model, the provider secures the cloud , including physical hardware and virtualization, while the customer secures within the cloud . In IaaS, this includes the guest OS, installed software, data, IAM, network configuration, encryption, and application configuration. |
| 2 C | Data poisoning occurs when malicious data is introduced into the training dataset, causing the resulting model to learn biased or incorrect information. Evasion instead occurs at inference time. |
| 3 C | PaaS provides a higher level of abstraction than IaaS. The study guide explicitly states that customer responsibility in PaaS falls somewhere between IaaS and SaaS and depends on the services being used. |
| 4 C | Model stealing involves recreating or approximating an AI model by querying the target model and using its responses, potentially exposing valuable intellectual property and competitive advantage. |
| 5 B | The Reliability pillar focuses on high availability, fault tolerance, failure recovery, elastic capacity, horizontal scaling, and automated recovery. |
| 6 B | Dependency pinning provides consistency and reproducibility, while lockfiles with checksums enforce dependency integrity. The guide also recommends automated CVE scanning. |
| 7 B | IAM policies should be narrow and granular. The study guide specifically gives the example of granting inference permissions to QA users while giving data-curation users permissions to update data stores. Policies should also be periodically reviewed. |
| 8 A | KMS supports customer-managed keys, allowing organizations to define customized rotation schedules and access policies. If a key is compromised, it can be rotated and access policies changed. |
| 9 B | Least privilege means granting users only the minimum access required for authorized tasks. Separating permissions according to functional responsibilities limits the blast radius of compromised identities. |

Q Answer Explanation

- 10 B** The guide states that VPCs can isolate sensitive AI resources and allow private API endpoints for inference, helping prevent sensitive data and model traffic from traversing the public internet.
- 11 C** IaC enables a desired infrastructure state to be defined declaratively and reproduced consistently. It also supports rapid management and detection of configuration drift.
- 12 B** The study guide specifically identifies sudden query surges and repeated unusual inputs as indicators that could suggest **model scraping/copying or adversarial testing**.
- 13 B** W3C Trace Context uses traceparent and tracestate headers to correlate activity across distributed services. This enables better diagnosis, root-cause analysis, and impact assessment.
- 14 A** Operational Excellence emphasizes **small reversible changes, frequent refinement, monitoring, and the ability to roll back deployments**.
- 15 B** AI monitoring needs to go beyond infrastructure metrics. The guide recommends monitoring model behavior, including confidence scores, distributions, drift, and anomalous usage, because both infrastructure and model behavior can reveal attacks.
- 16 C** Secure CI/CD should identify and prevent known vulnerabilities from being propagated into production. The sample questions similarly establish that a detected vulnerability should result in deployment being blocked until appropriately addressed.
- 17 C** A **clean-room environment** provides a safe and isolated location for forensic investigation. Module 8 explicitly identifies clean rooms as an incident-response capability.
- 18 A** RTO measures the targeted recovery time while RPO addresses acceptable data loss. Module 8 explicitly states there is an inverse relationship between these recovery objectives and cost: **lower desired RTO/RPO generally means higher cost**.
- 19 C** Module 8 explicitly states that AI agents should be treated as **user-like entities**, with every agent action requiring real-time verification regardless of previous authentication. Agents should receive only minimum necessary access.
- 20 B** Zero Trust Principle #2 states that **all communication is secured regardless of network location**. Being inside a private network does not create implicit trust.

Questions 21–40

This batch increases the emphasis on **scenario discrimination, control selection, trade-offs, and “BEST/MOST appropriate” reasoning**, while continuing coverage across the Module 8 study guide. The study guide emphasizes that AI cloud security spans conventional cloud controls as well as AI-specific threats such as model stealing, poisoning, and evasion.

Question 21

An organization discovers that a machine-learning model is producing increasingly inaccurate predictions several months after deployment. Security investigators find no evidence that the inference requests themselves were modified. They discover that malicious records were introduced into the training pipeline months earlier.

Which attack classification **BEST** describes the root cause?

- A. Evasion attack
 - B. Data poisoning
 - C. Model extraction
 - D. Distributed tracing failure
-

Question 22

A security architect is designing controls for a cloud-hosted AI system. The architect wants to ensure that compromise of one security layer does not automatically compromise the entire system.

Which AWS Well-Architected Security Pillar principle **MOST directly** addresses this objective?

- A. Traceability
 - B. Strong identity foundation
 - C. Security at all layers
 - D. Automation of security best practices
-

Question 23

A data scientist needs to run inference against a production AI model but must not modify the model artifact or access the underlying training dataset. A separate data-curation team needs permission to update the training data but does not need inference privileges.

Which IAM design **BEST** implements least privilege?

- A. Grant both teams full access to the model environment and rely on monitoring.
 - B. Give both teams read/write access because they are internal users.
 - C. Grant the data-curation team data-store update permissions and the data scientist inference permissions appropriate to their respective tasks.
 - D. Create a single shared role containing all permissions required by both teams.
-

Question 24

A company uses a cloud-managed database for storing AI training data. The organization wants to protect the database if an attacker gains access to the storage layer but does not possess the encryption key.

Which control provides the **MOST direct** protection?

- A. Network load balancing
 - B. Encryption at rest using KMS
 - C. Distributed tracing
 - D. Horizontal scaling
-

Question 25

An organization's AI platform uses provider-managed encryption keys by default. The security team now requires a customized key-rotation schedule and the ability to modify key access policies independently.

What should the team **MOST appropriately** implement?

- A. Customer-managed keys through KMS
 - B. TLS certificates for data at rest
 - C. A public VPC endpoint
 - D. Dependency lockfiles
-

Question 26

A company wants to rapidly create identical development, testing, and production environments for an AI workload. The security team also wants configuration changes to be reviewable and reproducible rather than dependent on manual administrator actions.

Which approach **BEST** satisfies these requirements?

- A. Manual provisioning followed by periodic audits
 - B. Infrastructure as Code with declarative configuration
 - C. Shared administrator accounts
 - D. Provider-managed SaaS deployment
-

Question 27

An AI platform is deployed across several cloud services. Security investigators can see individual service logs, but they cannot reliably determine which DNS request, API gateway call, serverless invocation, and inference request belong to the same user transaction.

What capability is **MOST directly missing**?

- A. Key rotation
- B. Distributed trace correlation

- C. Data-at-rest encryption
 - D. Dependency pinning
-

Question 28

A security engineer is reviewing logs generated by an AI inference API. The logs contain complete model outputs, including sensitive information from the model's training data.

What is the **MOST important concern** with the current logging implementation?

- A. Logs should never contain API information.
 - B. Logging should be avoided for AI systems because it creates additional storage requirements.
 - C. Logs must provide diagnostic value without unnecessarily exposing sensitive training data or model outputs.
 - D. Model outputs should always be logged in plaintext to maximize forensic value.
-

Question 29

A cloud AI service normally processes requests at a predictable rate. Monitoring detects a sudden increase in requests originating from a small number of clients, with many requests containing unusual variations of inputs.

Which response would be **MOST appropriate as an initial security action**?

- A. Treat the activity as potentially suspicious and investigate for adversarial probing or model extraction.
 - B. Immediately retrain the model using the new requests.
 - C. Delete all historical inference logs.
 - D. Disable encryption on the inference endpoint to improve performance.
-

Question 30

An organization wants monitoring to detect both conventional infrastructure problems and AI-specific anomalies.

Which monitoring strategy provides the **MOST comprehensive** approach?

- A. CPU utilization, memory utilization, and disk capacity only
 - B. Authentication failures and firewall events only
 - C. Infrastructure metrics combined with model performance, confidence distributions, drift, inference behavior, and anomalous query patterns
 - D. Model accuracy measured once every six months
-

Question 31

A team wants its monitoring platform to automatically trigger additional compute resources when inference demand increases and generate alerts when suspicious activity is detected.

Which capability described in Module 8 **BEST enables this**?

- A. Aggregating logs into metrics that can serve as inputs to automated behaviors
 - B. Removing severity levels from logs
 - C. Replacing IAM with network segmentation
 - D. Storing all logs exclusively in local files
-

Question 32

An organization wants to identify vulnerabilities in third-party software dependencies used by its MLOps pipeline before those dependencies reach production.

Which combination is **MOST appropriate**?

- A. Dependency pinning, lockfiles with checksums, and automated CVE scanning
 - B. Unrestricted dependency updates combined with manual production monitoring
 - C. Shared administrator credentials and periodic password rotation
 - D. Model retraining after every dependency update without vulnerability scanning
-

Question 33

A development team has implemented dependency pinning in its AI application. A developer argues that lockfiles are unnecessary because the dependency versions are already specified in the project configuration.

Which response is **MOST accurate according to Module 8**?

- A. Lockfiles are unnecessary when dependencies are pinned.
 - B. Lockfiles with checksums provide additional guarantees regarding dependency versions and integrity.
 - C. Lockfiles are useful only for operating-system packages.
 - D. Lockfiles primarily provide model-performance monitoring.
-

Question 34

A production AI model has been updated. Shortly afterward, users report degraded model performance. The organization wants the ability to determine what changed and, if necessary, return to the previous known-good state.

Which combination would **BEST** support this requirement?

- A. Version control, metadata tracking, model metrics, and automated reversion capabilities
 - B. Increasing the model's compute capacity
 - C. Removing model version information to simplify deployments
 - D. Disabling automated deployment pipelines
-

Question 35

During an AI security incident, responders determine that the inference endpoint has been compromised and may be facilitating continued unauthorized activity.

According to the Module 8 incident-response guidance, which action would be **MOST** appropriate?

- A. Continue serving traffic while investigators review the logs.
 - B. Quarantine or disable the inference endpoint as part of containment.
 - C. Permanently delete the entire production environment without preserving evidence.
 - D. Increase the model's inference rate to identify the attacker.
-

Question 36

A security team has created detailed incident-response documentation but responders still improvise during incidents because the documentation is not organized into actionable steps.

Which improvement would **BEST** address this problem?

- A. Replace the documentation with system dashboards.
 - B. Create runbooks containing pre-planned steps for standard incident activities.
 - C. Eliminate human involvement from incident response.
 - D. Store the documentation only in the production application's source code.
-

Question 37

An organization wants to validate whether its disaster recovery process actually works before a major outage occurs. It plans to simulate realistic failures involving operations, security, development, testing, and business stakeholders.

Which activity **BEST** matches this objective?

- A. Dependency pinning
- B. Game day
- C. Model extraction
- D. Key rotation

Question 38

A company conducts a game day for an AI workload. The team creates a test environment using IaC, assigns specific roles to participants, simulates a failure, preserves logs, and then removes the test environment.

What should the team do **NEXT** to derive maximum value from the exercise?

- A. Immediately repeat the same exercise without reviewing results.
 - B. Conduct a debrief, analyze monitoring and alerting results, identify weaknesses, and implement improvements.
 - C. Delete all exercise logs because they are no longer operationally relevant.
 - D. Permanently retain the isolated test environment without changes.
-

Question 39

An organization has established an RTO of 15 minutes for an AI service but an RPO of 24 hours. Management argues that because the RTO is very aggressive, the organization must also have an extremely low RPO.

Which response is **MOST accurate**?

- A. RTO and RPO are identical measures and should always have the same value.
 - B. RTO measures targeted recovery time, while RPO addresses acceptable data loss; they can therefore have different objectives.
 - C. RPO measures the time required to restore infrastructure.
 - D. RTO measures the amount of data that can be lost.
-

Question 40

A Zero Trust implementation evaluates access to an AI training dataset solely based on the user's department and permanent role assignment. It does not consider the requesting device, application, current risk, environmental conditions, or other contextual information.

Which Zero Trust principle is **MOST directly** being inadequately implemented?

- A. All data sources and computing services are considered resources.
 - B. Access is determined by dynamic policy using identity, application/service, requesting asset, and potentially behavioral/environmental attributes.
 - C. All communication is secured regardless of network location.
 - D. The enterprise collects information about asset and network state.
-

Answer Key & Explanations — Batch 2

Q Answer Explanation

- 21 B** **Data poisoning** occurs during the training phase when malicious data is introduced or legitimate data is removed or altered. The important distinction is timing: the compromise occurs in the training data/pipeline, rather than through malicious inference inputs.
- 22 C** The Security Pillar's **security at all layers** principle is designed so that compromise of one layer does not automatically compromise other layers. This creates layered security rather than reliance on a single defensive boundary.
- 23 C** Least privilege requires granular permissions aligned with actual responsibilities. Module 8 explicitly gives the example of QA users receiving inference permissions while data-curation users receive permissions to update the relevant data store.
- 24 B** **KMS-based encryption at rest** protects stored data even if an attacker gains access to the underlying data. Access to the encryption key through KMS is separately controlled.
- 25 A** Customer-managed keys allow organizations to exercise greater control over key-management policies, including customized rotation schedules and access policies.
- 26 B** IaC represents infrastructure as declarative configuration files, allowing environments to be created consistently and reproducibly. It also helps manage configuration drift and reduces manual error.
- 27 B** Distributed tracing allows a request to be correlated across multiple services. Module 8 recommends the W3C Trace Context standard using traceparent and tracestate, specifically for distributed AI applications.
- 28 C** AI logging needs to balance diagnostic and security value against privacy risk. The guide explicitly warns that logs should be designed so they do not inadvertently expose sensitive training data or model outputs.
- 29 A** Sudden query surges and repeated unusual inputs can indicate **adversarial testing or attempts to scrape/copy the model**. Such activity should therefore be investigated rather than automatically treated as ordinary demand.
- 30 C** AI observability must include both infrastructure and model behavior. Module 8 identifies confidence scores, distributions, drift detection, inference behavior, and unusual query patterns as important AI-specific monitoring signals.
- 31 A** Aggregating logs into metrics enables automation. Module 8 gives examples including automatic scaling and alerting based on anomalous behavior or resource thresholds.
- 32 A** Module 8 recommends **pinning dependencies**, using **lockfiles with checksums**, and performing automated **CVE scanning** to improve software supply-chain security and reproducibility.

Q Answer Explanation

- 33 B** Pinning controls the intended dependency version, while lockfiles with checksums add integrity and reproducibility guarantees. The study guide specifically recommends using both.
- 34 A** The continuous development/deployment pipeline should include model metadata tracking, metrics, and version control. Automation also supports reversion when changes introduce problems.
- 35 B** During containment, AI-specific actions may include **quarantining or disabling an inference endpoint**, rolling back a model version, or revoking tool-connector credentials.
- 36 B** **Runbooks** are detailed, pre-planned steps for standard incident activities. They reduce improvisation and help responders execute consistent procedures during an incident.
- 37 B** A **game day** simulates failures and exercises response procedures before an actual disruption. Module 8 describes involving operations, testing, development, security, business, and stakeholders.
- 38 B** The post-exercise debrief is a critical part of a game day. Teams should analyze logs, assess whether monitoring and alerting worked, identify process weaknesses, and implement improvements.
- 39 B** **RTO** concerns targeted recovery time, whereas **RPO** concerns acceptable data loss. They are distinct objectives and can therefore legitimately have different values. The module discusses both as separate recovery objectives.
- 40 B** Zero Trust Principle #4 requires access decisions based on **dynamic policy**, including the observable state of identity, application/service, and requesting asset, potentially incorporating behavioral and environmental attributes

Question 41

A company deploys an AI workload using cloud virtual machines. The cloud provider manages the physical data center, physical servers, and virtualization layer. The company's security team is responsible for patching the guest operating system and configuring security groups.

Which statement **BEST explains** this arrangement?

- A. The provider is violating the shared responsibility model because customers must manage physical infrastructure.
 - B. The customer is responsible for security *of* the cloud while the provider is responsible for security *in* the cloud.
 - C. The provider is responsible for security *of* the cloud, while the customer retains responsibility for security *in* the cloud.
 - D. The customer and provider are equally responsible for every security control.
-

Question 42

An organization moves an AI application from IaaS to a fully managed SaaS offering. The security team continues to require the internal application team to patch the underlying operating system and hypervisor.

What is the **MOST appropriate** assessment?

- A. The requirement remains mandatory because customers always patch operating systems in cloud environments.
 - B. The responsibility should be reassessed because SaaS shifts more infrastructure responsibility to the provider.
 - C. The application team should patch the provider's physical servers.
 - D. SaaS requires the customer to assume more infrastructure responsibilities than IaaS.
-

Question 43

An attacker modifies specially crafted inputs at inference time so that an image-classification model misclassifies objects, even though the training dataset has not been altered.

Which attack is this **MOST likely** to represent?

- A. Data poisoning
 - B. Model stealing
 - C. Evasion
 - D. Configuration drift
-

Question 44

A security architect is comparing data poisoning and evasion attacks.

Which statement **BEST distinguishes** the two?

- A. Data poisoning targets IAM, while evasion targets encryption.
 - B. Data poisoning manipulates training data, while evasion manipulates inputs presented to the model during inference.
 - C. Data poisoning occurs only in SaaS, while evasion occurs only in IaaS.
 - D. Data poisoning steals model weights, while evasion steals training data.
-

Question 45

An attacker sends thousands of carefully selected queries to a proprietary AI API and analyzes the returned outputs. The attacker does not directly compromise the model infrastructure.

Which security concern should the organization **MOST strongly** investigate?

- A. Model stealing
 - B. Data-center intrusion
 - C. Operating-system privilege escalation
 - D. Physical hardware tampering
-

Question 46

An AI platform has experienced repeated attacks against different components. The security team wants to avoid relying solely on a perimeter firewall and instead implement multiple independent security controls.

Which approach **BEST aligns** with Module 8?

- A. Security at all layers
 - B. Single perimeter security
 - C. Permanent implicit trust
 - D. Centralized administrator access
-

Question 47

An organization discovers that a developer's cloud credentials allow access to production databases, training datasets, model artifacts, and unrelated financial applications.

The developer only requires permission to deploy a particular AI application.

Which remediation is **MOST appropriate**?

- A. Increase the developer's logging requirements.
 - B. Rotate the developer's password but retain the permissions.
 - C. Restrict the identity to the minimum permissions required for the deployment function.
 - D. Give the developer a second administrator account for production.
-

Question 48

A security team wants to make IAM permissions easier to review. It currently has hundreds of users with individually assigned permissions.

Which design would **BEST improve manageability while supporting least privilege?**

- A. Assign all users administrator access.
 - B. Group permissions around defined roles and responsibilities.
 - C. Replace IAM with network segmentation.
 - D. Give users permanent access and review it only after an incident.
-

Question 49

A cloud AI workload stores sensitive training data in an object-storage service. The security team wants to ensure that unauthorized users cannot access the data even if they obtain direct access to the underlying storage objects.

Which control should be prioritized?

- A. Encryption at rest with controlled key access
 - B. Increasing compute capacity
 - C. Distributed tracing
 - D. Dependency pinning
-

Question 50

An organization uses customer-managed KMS keys for its AI workload. A security review identifies that the same key is used broadly by unrelated applications and many identities.

Which change would **BEST strengthen the key-management design?**

- A. Make the key publicly accessible.
- B. Review and restrict key access policies according to actual business and workload requirements.
- C. Disable key rotation.
- D. Store copies of the key inside application source code.

Question 51

An AI application is deployed within a VPC. Its inference endpoint is publicly accessible even though only internal applications should consume it.

Which change would **BEST reduce unnecessary exposure**?

- A. Replace the private VPC with a larger public subnet.
 - B. Use private API endpoints and appropriate network controls.
 - C. Disable IAM because the endpoint is an internal service.
 - D. Increase the model's inference capacity.
-

Question 52

An organization wants to enforce a standard network architecture across hundreds of AI workloads. Engineers currently create network configurations manually, and security reviews frequently discover inconsistent rules.

Which solution would **BEST address the problem at scale**?

- A. IaC with standardized security-reviewed templates
 - B. Manual configuration by senior administrators
 - C. Removing network segmentation
 - D. Creating a shared administrator account
-

Question 53

An AI development team uses IaC, but engineers can modify the infrastructure directly through the cloud console without updating the IaC definitions. Over time, the deployed infrastructure no longer matches the declared configuration.

What problem is **MOST directly** illustrated?

- A. Model poisoning
 - B. Configuration drift
 - C. Model stealing
 - D. Data exfiltration through inference
-

Question 54

A security operations team receives an alert that an AI inference service's request rate has increased dramatically. Before declaring an incident, the team wants to determine whether the increase is legitimate or malicious.

Which additional signal would be **MOST useful**?

- A. Whether the requests exhibit unusual patterns or originate from unexpected sources
 - B. Whether the cloud provider has changed its physical data center
 - C. Whether the model's source code has been rewritten
 - D. Whether the organization has recently rotated KMS keys
-

Question 55

A monitoring team tracks CPU utilization, memory, and network traffic but does not monitor changes in model confidence distributions or model behavior.

What important capability is the organization **MOST likely** missing?

- A. AI-specific observability
 - B. Physical security monitoring
 - C. Key-management infrastructure
 - D. Identity federation
-

Question 56

An AI service records detailed application events. The security team wants to standardize severity so that high-risk events receive immediate attention while informational events do not overwhelm responders.

Which logging approach **BEST supports this objective**?

- A. Treat all events identically.
 - B. Use structured logs with appropriate severity levels and contextual information.
 - C. Record only successful requests.
 - D. Remove timestamps from logs to reduce storage requirements.
-

Question 57

An AI application depends on an open-source package. A new vulnerability is published affecting the exact version used in production.

Which action should the organization **MOST appropriately** take within a secure MLOps process?

- A. Ignore the vulnerability because the package is open source.

- B. Identify the affected dependency, assess the risk, and remediate or upgrade it through the controlled deployment process.
 - C. Delete all model monitoring data.
 - D. Disable IAM controls until the dependency is upgraded.
-

Question 58

A team deploys a new AI model version. The model performs significantly worse than the previous version in production. The deployment pipeline has retained version metadata and metrics for both versions.

Which capability does this information **MOST directly enable**?

- A. Model version comparison and informed rollback/reversion
 - B. Physical server recovery
 - C. Key generation
 - D. Network address translation
-

Question 59

During a security incident, responders suspect that a compromised AI endpoint is being used to perform unauthorized actions through connected tools.

Which containment action is **MOST appropriate**?

- A. Increase the endpoint's privileges so investigators can inspect it.
 - B. Disable or quarantine the endpoint and revoke potentially compromised tool-connector credentials.
 - C. Permanently delete every cloud resource associated with the organization.
 - D. Allow the endpoint to continue operating until the investigation is complete.
-

Question 60

An organization is preparing its AI disaster-recovery strategy. Management states:

"We want almost instantaneous recovery and almost no data loss, regardless of cost."

Which response is **MOST consistent** with Module 8?

- A. Extremely low RTO and RPO objectives generally require greater investment and therefore higher cost.
- B. RTO and RPO have no relationship to infrastructure cost.
- C. Lower RTO always means greater acceptable data loss.

D. RPO measures the time required to recover the service.

Answer Key & Explanations — Batch 3

Q Answer Explanation

- 41 C** The Shared Responsibility Model distinguishes security **of** the cloud, which belongs primarily to the provider, from security **in** the cloud, where customer responsibilities depend on the service model. In IaaS, customers retain significant responsibility for guest OS, applications, data, IAM, and network configuration.
- 42 B** Moving from IaaS toward SaaS changes the responsibility boundary. SaaS places substantially more infrastructure responsibility with the provider, while the customer continues to have responsibilities such as data, identities, access, and appropriate configuration.
- 43 C** **Evasion attacks** manipulate inputs at inference time to cause an AI system to produce incorrect results. This contrasts with poisoning, which affects the training process/data.
- 44 B** The key distinction is **when and where the attack occurs**: poisoning targets training data, whereas evasion targets inputs presented during inference. This distinction is important when determining appropriate mitigations.
- 45 A** Repeatedly querying a model and analyzing outputs can enable an attacker to approximate the target model's behavior. Module 8 identifies this as **model stealing/model extraction**.
- 46 A** **Security at all layers** is a core security principle. It requires defense-in-depth rather than reliance on one perimeter control.
- 47 C** Least privilege requires removing unnecessary access and granting only what is required for the user's legitimate function. Excess permissions increase the potential blast radius of credential compromise.
- 48 B** Role-based and responsibility-aligned permissions make access easier to review and help enforce least privilege. Module 8 emphasizes narrow, granular policies aligned with actual responsibilities.
- 49 A** Encryption at rest protects stored data from unauthorized access, while controlled KMS permissions govern who can use the encryption keys. Module 8 specifically discusses KMS for protecting sensitive AI data.
- 50 B** Customer-managed keys provide control over key access policies. Broadly sharing a key with unrelated applications and identities undermines least privilege and increases the potential impact of key compromise.
- 51 B** Module 8 recommends VPC isolation and private API endpoints for sensitive AI resources where appropriate, reducing exposure of inference traffic to the public internet.

Q Answer Explanation

- 52 A** IaC allows security-reviewed infrastructure definitions to be reproduced consistently at scale. It also reduces manual configuration errors and assists with managing configuration drift.
- 53 B** **Configuration drift** occurs when the actual deployed infrastructure diverges from the intended configuration. Allowing uncontrolled manual changes outside IaC is a common source of drift.
- 54 A** A query-rate increase alone does not establish an attack. Additional context such as source, input patterns, and behavioral anomalies can help distinguish legitimate demand from adversarial probing or model extraction.
- 55 A** Traditional infrastructure metrics are insufficient for comprehensive AI observability. Module 8 recommends monitoring model-specific signals such as confidence scores, distributions, drift, and anomalous inference behavior.
- 56 B** Structured logs with severity levels and contextual information make logs more useful for detection, triage, investigation, and automated alerting. The module also emphasizes that logging should avoid unnecessary exposure of sensitive information.
- 57 B** Secure MLOps requires dependency management and vulnerability scanning. When a vulnerability affects a dependency, the organization should assess and remediate it through a controlled deployment process rather than ignoring it. Module 8 specifically recommends automated CVE scanning.
- 58 A** Model metadata, version control, and metrics allow teams to compare model versions and support controlled rollback/reversion when a new model performs poorly.
- 59 B** Module 8 identifies containment actions including quarantining/disabling an inference endpoint and revoking compromised tool-connector credentials. These actions limit continued unauthorized activity while preserving the possibility of investigation.
- 60 A** RTO and RPO represent recovery objectives. Achieving very low recovery time and very low acceptable data loss generally requires more sophisticated infrastructure and therefore greater cost. Module 8 explicitly describes this inverse relationship

Question 61

An organization is migrating an AI application from on-premises infrastructure to IaaS. The project manager states that because the cloud provider operates the infrastructure, the organization no longer needs to perform vulnerability management on the application servers.

Which response is **MOST accurate**?

- A. Correct, because vulnerability management becomes entirely the provider's responsibility in IaaS.
 - B. Correct, provided the application is deployed inside a VPC.
 - C. Incorrect, because the customer remains responsible for security controls within the cloud, including relevant guest operating-system and application security.
 - D. Incorrect, because the customer becomes responsible for physical security of the cloud provider's facilities.
-

Question 62

A company operates an AI service in which customers submit queries through an API. Security monitoring identifies an attacker who is systematically modifying inputs to cause the model to produce incorrect classifications.

The attacker does not modify the training dataset.

Which mitigation would **MOST directly** address this threat?

- A. Strengthen controls around training-data integrity and provenance.
 - B. Monitor and detect anomalous inference inputs and behavior.
 - C. Rotate the physical servers hosting the model.
 - D. Replace customer-managed KMS keys with provider-managed keys.
-

Question 63

A machine-learning team wants to protect its training pipeline from malicious modifications to datasets. The organization also wants to be able to determine where every training record originated.

Which combination would **BEST** support these objectives?

- A. Data provenance controls combined with integrity monitoring
 - B. Publicly accessible data stores combined with anonymous access
 - C. Distributed tracing alone
 - D. Model-output monitoring alone
-

Question 64

An attacker has obtained access to an AI model's prediction API but has no access to its source code, model weights, or training dataset. The attacker repeatedly queries the API and uses the outputs to construct a substitute model.

Which security objective is **MOST directly** threatened?

- A. Availability
 - B. Confidentiality of model intellectual property
 - C. Physical security
 - D. Network latency
-

Question 65

An AI platform contains the following components:

- Training data store
- Model registry
- Inference endpoint
- CI/CD pipeline
- Monitoring platform

The security architect wants to ensure that compromise of the CI/CD pipeline cannot automatically provide unrestricted access to all other components.

Which design principle should be **PRIORITIZED**?

- A. Centralize all permissions under one service account.
 - B. Apply granular IAM permissions and security controls at each layer.
 - C. Remove authentication between internal services.
 - D. Give the CI/CD pipeline administrator privileges to simplify deployment.
-

Question 66

A security team discovers that an AI application's service account has permissions to delete production training data even though the application only needs to read the data.

Which action is **BEST**?

- A. Keep the permission because service accounts are trusted.
- B. Replace the service account with a shared administrator account.
- C. Remove the unnecessary delete permission and retain only required access.
- D. Disable audit logging because the account is automated.

Question 67

A cloud AI workload uses customer-managed encryption keys. During an investigation, the security team determines that a compromised identity has permission to use the encryption key for several unrelated applications.

What is the **MOST appropriate** security response?

- A. Review and tighten the KMS key policy and revoke unnecessary access.
 - B. Publish the key policy so all teams can review it anonymously.
 - C. Disable encryption to eliminate key-management risk.
 - D. Copy the encryption key into each application so access can be controlled locally.
-

Question 68

A security architect wants to ensure that sensitive AI data does not traverse the public internet when applications access the inference service.

Which architecture is **MOST appropriate**?

- A. Public API endpoint protected only by a password
 - B. Private networking with appropriately configured private endpoints
 - C. Public endpoint with unrestricted access but increased CPU capacity
 - D. Internet-facing endpoint with no authentication but encrypted model weights
-

Question 69

An organization manages its cloud infrastructure using IaC. A security engineer proposes that every production change should first modify the IaC definition and then be applied through the approved deployment pipeline.

What is the **PRIMARY security benefit** of this approach?

- A. It eliminates the need for authentication.
 - B. It improves consistency, traceability, and control over infrastructure changes.
 - C. It guarantees that the AI model cannot be poisoned.
 - D. It removes the need for monitoring.
-

Question 70

A cloud administrator manually changes a production security-group rule to permit additional inbound traffic. The change is not reflected in the organization's IaC repository.

Two weeks later, another deployment overwrites the rule unexpectedly.

What is the **BEST** explanation?

- A. The model experienced an evasion attack.
 - B. The organization has a configuration-drift problem.
 - C. The KMS key has expired.
 - D. The incident is caused by model stealing.
-

Question 71

A security operations team wants to reconstruct an AI transaction that passed through multiple distributed services. Each service produces its own logs, but there is no common identifier connecting the events.

Which improvement would **MOST directly** help?

- A. Introduce distributed tracing with a common trace context.
 - B. Increase the retention period of unrelated logs.
 - C. Encrypt all logs with a new KMS key.
 - D. Increase the inference endpoint's compute capacity.
-

Question 72

An AI inference platform records model confidence scores. Over several weeks, the distribution of confidence scores changes significantly even though the application workload appears stable.

Why should the security team investigate this change?

- A. Model behavior can provide security-relevant signals and may indicate drift or anomalous activity.
 - B. Confidence scores are purely performance metrics and cannot have security relevance.
 - C. The change proves that the KMS key has been compromised.
 - D. The change proves that the cloud provider has modified the physical infrastructure.
-

Question 73

A security team notices that an AI service has begun generating unusually large numbers of low-confidence predictions from a particular source. No known software vulnerability has been reported.

What is the **BEST initial approach**?

- A. Immediately assume the model weights were stolen.
- B. Investigate the source, input characteristics, model behavior, and related telemetry for anomalous or adversarial activity.

- C. Delete the model and all historical telemetry.
 - D. Disable all monitoring because the model is still available.
-

Question 74

An organization has implemented extensive logging for an AI workload. However, the logs contain sensitive prompts, model outputs, and potentially confidential training information.

Which principle should **MOST influence** the redesign?

- A. Logs should maximize data collection regardless of sensitivity.
 - B. Logging should provide useful diagnostic/security information while avoiding unnecessary exposure of sensitive data.
 - C. AI systems should never generate logs.
 - D. Only infrastructure logs should be retained.
-

Question 75

A software pipeline automatically downloads the latest version of every dependency whenever an AI application is built. The organization has experienced unexpected changes in production behavior.

Which change would **BEST improve reproducibility and supply-chain security**?

- A. Allow even more automatic dependency updates.
 - B. Pin dependency versions and use lockfiles with integrity checks.
 - C. Remove dependency scanning.
 - D. Give developers administrator privileges over production.
-

Question 76

A security scanner identifies a critical CVE in a dependency used by the production model-serving application. The vulnerable package cannot immediately be upgraded because the new version is incompatible with the application.

What should the organization **MOST appropriately** do?

- A. Ignore the vulnerability because upgrading is inconvenient.
 - B. Assess the vulnerability, apply an appropriate compensating/remediation measure, and manage the dependency through the controlled development process.
 - C. Disable all security scanning.
 - D. Replace the model with a completely unrelated model without assessing the dependency.
-

Question 77

A new model version is deployed automatically. The monitoring system detects a significant degradation in performance immediately after deployment.

Which capability would **MOST reduce the operational impact**?

- A. Automated rollback to a known-good model version
 - B. Removing version identifiers from model artifacts
 - C. Disabling monitoring during deployment
 - D. Giving the model unrestricted access to production systems
-

Question 78

During a major AI security incident, the response team immediately begins making changes to production systems. Several responders perform different containment actions simultaneously, and no one is sure which changes were made.

Which preparation would **BEST reduce this problem in future incidents**?

- A. Predefined incident-response runbooks and clearly assigned roles
 - B. Eliminate incident documentation to reduce bureaucracy
 - C. Give every responder unrestricted administrator access
 - D. Disable centralized logging during incidents
-

Question 79

An organization conducts an AI disaster-recovery exercise and discovers that its recovery process technically works but takes significantly longer than the defined RTO.

What should the organization **MOST appropriately** do?

- A. Change the RTO documentation so the test automatically passes.
 - B. Treat the result as a gap, determine the cause, and improve the recovery architecture/process or reassess the business requirement.
 - C. Stop conducting disaster-recovery tests.
 - D. Delete the exercise records.
-

Question 80

A Zero Trust architecture has been implemented for an AI platform. A developer authenticated successfully in the morning and therefore receives unrestricted access to production model resources for the remainder of the day.

Which principle is **MOST directly** violated?

- A. Assume trust after initial authentication.
- B. Verify explicitly and enforce least-privilege access continuously.
- C. Allow all internal traffic after authentication.
- D. Trust users based on network location.

Answer Key & Explanations — Batch 4

Q Answer Explanation

- 61 C** In IaaS, the provider manages underlying infrastructure, but the customer remains responsible for security within the cloud. This includes relevant guest OS, applications, data, IAM, and network configuration. The Shared Responsibility Model does not eliminate customer security responsibilities.
- 62 B** The scenario describes an **evasion attack**, where inference inputs are manipulated to cause incorrect model behavior. Monitoring anomalous inputs and inference behavior is therefore directly relevant. Data-integrity controls are more directly applicable to poisoning attacks.
- 63 A** Data provenance helps establish where training data originated, while integrity monitoring helps identify unauthorized modification. Together they provide stronger protection of the training-data supply chain. Module 8 emphasizes protecting the data pipeline as part of AI security.
- 64 B** The attacker is attempting **model stealing**, which can compromise the confidentiality of proprietary model behavior and intellectual property even without directly obtaining the model weights.
- 65 B** Defense in depth requires security controls at multiple layers, while granular IAM prevents compromise of one component from automatically granting unrestricted access elsewhere. Module 8 emphasizes narrow, granular policies and security at all layers.
- 66 C** Least privilege requires removing unnecessary permissions. An application that only reads data should not retain permission to delete it. This reduces the potential impact of a compromised service account.
- 67 A** Customer-managed KMS keys allow organizations to define and modify key access policies. Unnecessary identities should be removed from the key policy to reduce the blast radius of credential compromise.
- 68 B** Private endpoints and appropriate VPC/network controls can prevent sensitive AI traffic from unnecessarily traversing the public internet. Module 8 specifically recommends VPC isolation and private API endpoints for sensitive AI resources.

Q Answer Explanation

- 69 B** IaC creates a declarative, reproducible representation of infrastructure. Routing changes through an approved pipeline improves consistency and makes infrastructure changes more traceable and controllable.
- 70 B** The actual deployed configuration has diverged from the intended IaC definition. This is **configuration drift**. Module 8 specifically identifies IaC as a means of managing desired infrastructure state and detecting drift.
- 71 A** Distributed tracing correlates events across multiple services. Module 8 recommends the W3C Trace Context standard, including traceparent and tracestate, for distributed AI applications.
- 72 A** AI-specific observability includes monitoring confidence scores and distributions. Unexpected changes can reveal model drift or anomalous behavior and therefore deserve investigation.
- 73 B** A security investigation should correlate the source, input characteristics, model behavior, and telemetry rather than immediately assigning a specific attack classification. Module 8 recommends monitoring unusual query patterns and model behavior as potential indicators of adversarial activity.
- 74 B** Logging should provide sufficient information for detection, investigation, and operational visibility while avoiding unnecessary exposure of sensitive training data or model outputs.
- 75 B** Dependency pinning and lockfiles with checksums improve reproducibility and help protect the software supply chain. Module 8 also recommends automated vulnerability/CVE scanning.
- 76 B** A known vulnerability should not simply be ignored. Where immediate upgrade is impractical, the organization should assess the risk and implement appropriate remediation/compensating measures while managing the dependency through the controlled MLOps process.
- 77 A** Version control, metrics, and automated reversion support safe model deployment. If a new model produces unacceptable results, automatic rollback to a known-good version can limit operational impact.
- 78 A** Incident-response runbooks provide predefined procedures, while assigned roles clarify responsibilities. These reduce improvisation and coordination problems during incidents.
- 79 B** An RTO is a business/technical recovery objective. If testing shows that the actual recovery process cannot meet it, the organization should identify the gap and either improve its recovery capability or formally reassess the requirement. Game days are specifically intended to identify such weaknesses.

Q Answer Explanation

80 B

Zero Trust does not establish permanent trust after initial authentication. Access should be explicitly verified and governed by least privilege and dynamic policy. Module 8 specifically states that AI agents should be treated as user-like entities requiring real-time verification of each action.

Question 81

An organization deploys an AI application on IaaS. The application team assumes that because the cloud provider manages the physical infrastructure, the provider will also configure the application's IAM policies, encrypt the organization's data, and secure its application code.

Which response is **MOST accurate**?

- A. The assumption is correct because all security responsibilities transfer to the cloud provider in IaaS.
 - B. The assumption is incorrect because the customer retains significant responsibility for security within the cloud, including IAM, data, applications, and relevant configuration.
 - C. The assumption is correct if the organization uses customer-managed encryption keys.
 - D. The assumption is incorrect because the customer is responsible for securing the provider's physical data centers.
-

Question 82

A security team is investigating an AI incident. It discovers that:

1. An attacker modified a portion of the training dataset.
2. Several months later, the model began producing biased predictions.
3. The attacker never directly interacted with the production inference API.

Which conclusion is **MOST appropriate**?

- A. The incident is primarily an evasion attack.
 - B. The incident is primarily a model-stealing attack.
 - C. The incident is consistent with data poisoning.
 - D. The incident is primarily a distributed-tracing failure.
-

Question 83

A model-serving endpoint is experiencing an unusual pattern of carefully crafted queries. The security team suspects that an attacker is attempting to reproduce the proprietary model's behavior.

Which evidence would provide the **STRONGEST support** for the model-stealing hypothesis?

- A. The attacker's queries systematically explore the model's decision boundaries and use the responses to build a substitute model.
 - B. The model's training dataset contains unauthorized records.
 - C. The application's CPU utilization has decreased.
 - D. The organization's KMS key was rotated recently.
-

Question 84

An organization wants to reduce the likelihood that compromise of one AI workload will allow an attacker to compromise other workloads in the same cloud environment.

Which combination would provide the **BEST defense-in-depth strategy**?

- A. Shared administrator credentials and a single security group
 - B. Granular IAM, network segmentation, encryption, monitoring, and security controls at multiple layers
 - C. A single perimeter firewall with unrestricted internal access
 - D. One shared service account with extensive permissions
-

Question 85

A cloud AI application has three roles:

- Data Curator — modifies approved training datasets
- Model Developer — trains and validates models
- Inference Operator — deploys approved models and manages inference

Which IAM strategy is **MOST appropriate**?

- A. Give all three roles administrator permissions because they all work on the same AI platform.
 - B. Give each role narrowly scoped permissions aligned to its responsibilities and periodically review those permissions.
 - C. Give the Inference Operator access to all training data because deployment is part of the AI lifecycle.
 - D. Use one service account for all three roles to simplify auditing.
-

Question 86

A security architect is designing an AI platform containing sensitive training data and proprietary models. The architect wants to ensure that access to the workload is not implicitly trusted simply because a request originates from the organization's internal network.

Which principle **MOST directly** supports this requirement?

- A. Trust internal network traffic by default.
 - B. Secure all communication regardless of network location.
 - C. Allow unrestricted access after VPN authentication.
 - D. Grant permanent access to employees within the corporate network.
-

Question 87

An AI service is accessible through a public endpoint even though all legitimate consumers are internal applications within the organization's cloud environment.

Which change would **MOST directly** reduce the exposure?

- A. Increase the endpoint's processing capacity.
 - B. Replace the public endpoint with an appropriately configured private endpoint.
 - C. Disable authentication because all consumers are internal.
 - D. Increase log-retention duration.
-

Question 88

An organization uses IaC to provision its AI infrastructure. During an audit, the security team discovers that several engineers routinely make direct production changes through the cloud console.

What is the **PRIMARY security concern**?

- A. The practice can create configuration drift and weaken consistency and traceability of infrastructure changes.
 - B. Direct console changes automatically cause model poisoning.
 - C. IaC becomes unnecessary once cloud resources are deployed.
 - D. Direct console changes eliminate the need for IAM.
-

Question 89

An AI platform's monitoring system reports:

- Normal CPU utilization
- Normal memory utilization
- Significant increase in low-confidence predictions
- Significant change in prediction distributions

- Unusual increase in queries from a small number of clients

What should the security team **MOST appropriately** conclude?

- A. Infrastructure health proves that there is no security issue.
 - B. The combined AI-specific indicators warrant investigation for anomalous or adversarial activity.
 - C. The KMS key must have expired.
 - D. The cloud provider's physical infrastructure must have failed.
-

Question 90

A security engineer wants to correlate a suspicious API request across DNS, API Gateway, serverless processing, and the AI inference service.

Which capability would **BEST support this investigation**?

- A. W3C Trace Context using distributed tracing
 - B. Customer-managed KMS keys
 - C. Dependency pinning
 - D. Horizontal scaling
-

Question 91

An AI development team discovers that two supposedly identical environments are using different versions of a critical Python dependency.

Which control would **MOST directly** reduce the likelihood of this problem recurring?

- A. Dependency pinning and lockfiles with checksums
 - B. Increasing the model's inference capacity
 - C. Removing version information from deployments
 - D. Allowing unrestricted automatic dependency updates
-

Question 92

A security team wants its MLOps pipeline to prevent a known vulnerable dependency from being introduced into production.

Which control would **BEST address the requirement**?

- A. Automated CVE scanning integrated into the software supply-chain process
- B. Disabling dependency management
- C. Manually reviewing source code once per year

D. Removing dependency versions from build artifacts

Question 93

A new model is deployed to production. Automated monitoring detects that its performance has degraded significantly compared with the previous model version.

Which capability should the organization **MOST want available**?

- A. Automated rollback/reversion to a known-good model version
 - B. Removal of the previous model version
 - C. Disabling model monitoring during deployment
 - D. Permanent administrator access for the model
-

Question 94

During an AI incident, responders need to investigate a compromised workload while minimizing the risk of altering evidence or affecting other production resources.

Which approach is **MOST appropriate**?

- A. Conduct the investigation directly on the production system without isolation.
 - B. Use an isolated clean-room environment for forensic analysis.
 - C. Delete the compromised workload immediately without preserving evidence.
 - D. Disable all logging before beginning the investigation.
-

Question 95

An organization has an incident-response plan but discovers during an exercise that responders do not know who is responsible for containment, communications, evidence preservation, and recovery.

Which improvement would **BEST address the weakness**?

- A. Create predefined roles, responsibilities, and incident-response runbooks.
 - B. Give every responder unrestricted administrator access.
 - C. Remove the incident-response plan.
 - D. Allow responders to determine responsibilities during the incident.
-

Question 96

An organization conducts a disaster-recovery game day for its AI platform. The exercise reveals that the recovery process takes 45 minutes, but the approved RTO is 15 minutes.

What is the **BEST next step**?

- A. Declare the exercise successful because recovery was eventually achieved.
 - B. Analyze the gap and either improve the recovery capability or formally reassess the business recovery requirement.
 - C. Change the RTO to 45 minutes without stakeholder approval.
 - D. Stop conducting game days because they reveal too many weaknesses.
-

Question 97

A business requires an AI service to recover within five minutes and tolerate no more than one minute of data loss. Another business-critical but less time-sensitive application has an RTO of eight hours and an RPO of 24 hours.

Which conclusion is **MOST appropriate**?

- A. Both applications should use the same architecture because all business-critical systems require identical recovery objectives.
 - B. The first application's lower RTO/RPO requirements will generally require greater investment than the second application's less stringent requirements.
 - C. RPO only affects application performance and not recovery architecture.
 - D. RTO and RPO should be determined solely by the cloud provider.
-

Question 98

An AI agent has permission to access a sensitive database. The organization currently authenticates the agent once and then allows it to execute database operations indefinitely.

Which redesign **BEST aligns with Module 8's Zero Trust guidance for AI agents**?

- A. Trust the agent indefinitely after its initial authentication.
 - B. Treat the agent as a user-like entity, verify each action in real time, and provide only minimum necessary access.
 - C. Give the agent administrator privileges to avoid authorization failures.
 - D. Allow the agent unrestricted access as long as all actions are logged.
-

Question 99

A Zero Trust implementation team is defining an access policy for an AI resource.

Which policy **BEST reflects Zero Trust Principle #4**?

- A. "Any authenticated employee may access the resource."

- B. "Any device connected to the corporate network may access the resource."
- C. "Access is determined dynamically using identity, application/service, requesting asset, and relevant behavioral or environmental attributes."
- D. "Employees may access the resource permanently after completing annual security training."
-

Question 100

An organization is designing security architecture for a highly regulated AI platform. The architect proposes the following:

- Least-privilege IAM
- Customer-managed KMS keys
- VPC isolation and private endpoints
- IaC
- Dependency pinning and CVE scanning
- AI-specific monitoring
- Distributed tracing
- Incident-response runbooks
- Game-day exercises
- Zero Trust controls for AI agents

Which statement **BEST** characterizes this architecture?

- A. It focuses primarily on network security and therefore provides limited AI security.
- B. It combines cloud security, secure deployment, MLOps security, observability, incident response, disaster recovery, and Zero Trust principles.
- C. It eliminates the need for human security oversight because most controls are automated.
- D. It primarily addresses physical security and does not address AI-specific threats.
-

Answer Key & Explanations — Batch 5

Q Answer Explanation

81 B

The Shared Responsibility Model does not eliminate customer responsibilities in IaaS. The provider secures the underlying cloud infrastructure, while the customer remains responsible for security within the cloud, including relevant IAM, data, applications, OS, and configuration.

Q Answer Explanation

- 82 C The attack occurs by modifying training data before the model learns from it. This is the defining characteristic of **data poisoning**. The timing distinguishes it from inference-time evasion.
- 83 A Systematically querying the model to explore its behavior and then using those outputs to create a substitute model is characteristic of **model stealing**. The attacker does not need direct access to the original model weights.
- 84 B Defense in depth combines multiple independent security layers. Granular IAM limits identity compromise, network segmentation limits lateral movement, encryption protects data, and monitoring improves detection. This is consistent with the Security Pillar principle of security at all layers.
- 85 B IAM should be aligned with actual job responsibilities. Data curators should have appropriate data-store permissions, model developers should have model-development permissions, and inference operators should have deployment/inference permissions. Policies should also be reviewed periodically.
- 86 B Zero Trust Principle #2 states that **all communication is secured regardless of network location**. Being inside a corporate network does not establish implicit trust.
- 87 B If legitimate consumers are internal, a private endpoint can reduce unnecessary public exposure. Module 8 specifically identifies private API endpoints as a way to protect sensitive AI resources.
- 88 A Manual changes outside IaC can cause the deployed environment to diverge from the declared configuration. This creates **configuration drift** and weakens the consistency and traceability benefits of IaC.
- 89 B Normal infrastructure metrics do not prove that an AI system is secure. The combination of low-confidence predictions, distribution changes, and unusual query behavior represents important AI-specific signals that should be investigated.
- 90 A Distributed tracing allows events across multiple services to be correlated. Module 8 specifically references W3C Trace Context and its traceparent and tracestate mechanisms for distributed AI applications.
- 91 A Dependency pinning and lockfiles with checksums improve reproducibility by ensuring environments use consistent dependency versions and help establish dependency integrity.
- 92 A Automated CVE scanning helps identify known vulnerabilities in dependencies before they are propagated through the software supply chain and into production. Module 8 explicitly recommends this practice.
- 93 A Model versioning, metrics, and automated reversion provide the ability to return to a known-good version when a deployment causes unacceptable degradation.

Q Answer Explanation

- 94 B** Module 8 identifies the use of a **clean-room environment** as an incident-response capability for safe and isolated forensic investigation. It helps reduce the risk of contaminating evidence or affecting other systems.
- 95 A** Runbooks provide predefined procedures, while defined roles and responsibilities ensure responders understand who owns containment, communication, evidence preservation, and recovery activities.
- 96 B** A game day is designed to identify weaknesses in recovery processes. If the actual recovery time exceeds the RTO, the organization should investigate the gap and either improve recovery capabilities or reassess the requirement with the appropriate business stakeholders.
- 97 B** Lower RTO and RPO requirements generally require greater investment in resilient architecture, backup/recovery mechanisms, redundancy, and operational capabilities. Therefore, the first application would generally require more expensive recovery capabilities than the second.
- 98 B** Module 8 specifically extends Zero Trust concepts to AI agents: agents should be treated as user-like entities, with each action requiring real-time verification and only the minimum necessary access.
- 99 C** Zero Trust Principle #4 uses **dynamic policy** based on identity, application/service, requesting asset, and potentially behavioral and environmental attributes. Static trust based solely on employment status or network location does not satisfy this principle.
- 100 B** The architecture covers essentially the full Module 8 lifecycle: cloud security responsibilities, IAM/KMS/network controls, IaC and software supply-chain security, AI observability, incident response, DR/game days, and Zero Trust—including the specific treatment of AI agents